

API Documentation

Identity Portal — Password Reset Bot

Base URL	http://localhost:8000
Framework	Python FastAPI
Auth	None (sandbox/demo environment)
Content-Type	application/json
Total Endpoints	5
Version	v1.0

API Endpoint Index

#	Method	Endpoint	Purpose
1	POST	/api/validate-email	Validate user email against DB
2	POST	/api/generate-otp	Generate & email OTP to user
3	POST	/api/verify-otp	Verify submitted OTP token
4	POST	/api/reset-password	Hash & update new password in DB
5	GET	/api/audit-log	Retrieve audit event log

01 Validate Email

POST**/api/validate-email****Check User in Database**

Accepts a user-supplied email address and queries the SQLite users table. Returns whether the email is registered and triggers the OTP flow if valid. On failure, logs a `USER_NOT_FOUND` event without revealing whether the email exists.

Request Body

Field	Type	Required	Description
email	string	Yes	Registered email address of the user

Response Body

Field	Type	Required	Description
success	boolean	Yes	true if email found in DB
message	string	Yes	Human-readable status message
event	string	Yes	Audit event code (e.g. <code>USER_FOUND</code>)

Example

Request	Response
<pre>{ "email": "madhavankann657@gmail.com" }</pre>	<pre>{ "success": true, "message": "User verified.", "event": "USER_FOUND" }</pre>

Error Responses

Code	Status	Message
404	<code>USER_NOT_FOUND</code>	Email not registered in the system
422	<code>VALIDATION_ERROR</code>	Invalid email format or missing field

02 Generate OTP

POST**/api/generate-otp****Create & Dispatch OTP**

Generates a cryptographically secure 6-digit OTP using Python's `secrets` module. Stores the token in the database with a 10-minute expiry timestamp and dispatches it to the user's email via the configured SMTP server (MailHog in sandbox mode).

Request Body

Field	Type	Required	Description
email	string	Yes	Verified email address (must pass <code>/validate-email</code> first)

Response Body

Field	Type	Required	Description
success	boolean	Yes	true if OTP generated and sent
message	string	Yes	Confirmation message
event	string	Yes	<code>OTP_GENERATED</code> or <code>OTP_SENT</code>
expires_in	integer	Yes	OTP validity in seconds (600)

Example

Request	Response
<pre>{ "email": "madhavankann657@gmail.com" }</pre>	<pre>{ "success": true, "message": "OTP sent to email.", "event": "OTP_SENT", "expires_in": 600 }</pre>

Error Responses

Code	Status	Message
400	EMAIL_NOT_VERIFIED	Validate email before requesting OTP
500	SMTP_ERROR	Email dispatch failed (check SMTP config)

03 Verify OTP

POST**/api/verify-otp****Validate User-Submitted Token**

Compares the submitted OTP against the stored token for the given email. Checks expiry timestamp before comparison. On success, marks the OTP as consumed and returns a session token to authorise the password reset step. Failed attempts are logged to the audit trail.

Request Body

Field	Type	Required	Description
email	string	Yes	Email address the OTP was sent to
otp	string	Yes	6-digit OTP entered by the user

Response Body

Field	Type	Required	Description
success	boolean	Yes	true if OTP matched and not expired
message	string	Yes	Status message
event	string	Yes	OTP_VERIFIED or OTP_FAILED
reset_token	string	No	Short-lived token to authorise password reset

Example

Request	Response
<pre>{ "email": "madhavankann657@gmail.com", "otp": "705313" }</pre>	<pre>{ "success": true, "message": "OTP verified.", "event": "OTP_VERIFIED", "reset_token": "tok_abc123" }</pre>

Error Responses

Code	Status	Message
400	OTP_INVALID	Submitted OTP does not match stored token
410	OTP_EXPIRED	OTP exceeded 10-minute validity window
409	OTP_CONSUMED	OTP already used in a previous request

04 Reset Password

POST**/api/reset-password****Hash & Persist New Password**

Accepts the new password after OTP verification is confirmed. Runs a password strength check, then hashes the value using SHA-256 before writing to the SQLite users table. Plaintext is discarded immediately after hashing. A PASSWORD_RESET audit event is created on success.

Request Body

Field	Type	Required	Description
email	string	Yes	Verified email address
reset_token	string	Yes	Token returned by /verify-otp
new_password	string	Yes	New password (min 8 chars, 1 upper, 1 digit, 1 special)

Response Body

Field	Type	Required	Description
success	boolean	Yes	true if password updated in DB
message	string	Yes	Confirmation message
event	string	Yes	PASSWORD_RESET

Example

Request	Response
<pre>{ "email": "madhavankann657@gmail.com", "reset_token": "tok_abc123", "new_password": "Makeit123@" }</pre>	<pre>{ "success": true, "message": "Password updated successfully.", "event": "PASSWORD_RESET" }</pre>

Error Responses

Code	Status	Message
400	WEAK_PASSWORD	Password fails strength requirements
401	INVALID_RESET_TOKEN	reset_token missing, expired, or already used
409	SAME_PASSWORD	New password matches current stored hash

05 Audit Log

GET /api/audit-log **Retrieve Event History**

Returns the full audit event log stored in the SQLite audit_logs table. Each record captures the event type, associated email (or anonymous), and a UTC timestamp. Supports optional filtering by email or event type via query params.

Response Body

Field	Type	Required	Description
events	array	Yes	List of audit event objects
events[].id	integer	Yes	Auto-incremented log entry ID
events[].event	string	Yes	Event code (RESET_REQUESTED, OTP_SENT, etc.)
events[].email	string	Yes	Actor email or anonymous
events[].timestamp	string	Yes	ISO-8601 UTC timestamp

Example

Request	Response
<pre>GET /api/audit-log?email=madhavankann657@gmail.com</pre>	<pre>{ "events": [{ "id": 7, "event": "PASSWORD_RESET", "email": "madha...@gmail.com", "timestamp": "2025-02-28T02:38:41Z" }] }</pre>

Error Responses

Code	Status	Message
400	INVALID_FILTER	Unrecognised query parameter supplied

Audit Event Code Reference

Event Code	Trigger	Severity
RESET_REQUESTED	User initiates password reset	INFO
USER_FOUND	Email matched in DB	INFO
USER_NOT_FOUND	Email not registered	WARN
OTP_GENERATED	OTP created and saved	INFO
OTP_SENT	OTP dispatched via SMTP	INFO
OTP_VERIFIED	Correct OTP submitted	INFO
OTP_FAILED	Incorrect OTP submitted	WARN
OTP_EXPIRED	OTP submission after 10-min window	WARN
PASSWORD_RESET	Password successfully updated in DB	INFO
FAILED_ATTEMPT	Multiple failed OTP retries	ERROR